

SEC571 FINAL PROJECT: DEFENSE-IN-DEPTH FOR PRC ACCESS CONTROL SECURITY

Joseph Ledezma

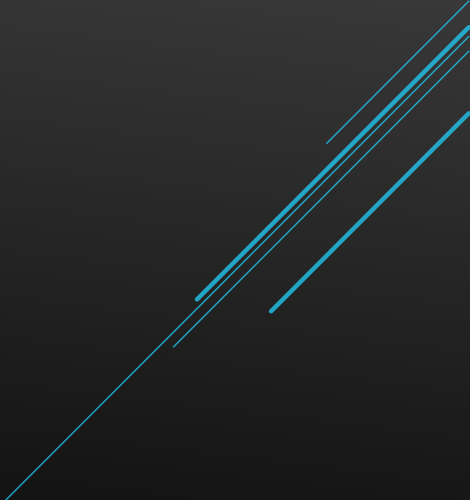
January Session

02/28/2026

Professor: Jonathan Coombes

INTRODUCTION

This project analyzes cybersecurity risks within the Nestlé Gerber Parent Resource Center (PRC), a consumer-facing department responsible for handling sensitive parent and child information, including personally identifiable and health-related data. Operating in a shared, high-traffic office environment, the PRC faces elevated exposure to physical and logical access threats that could compromise the confidentiality, integrity, and availability of critical information assets. Using a Defense-in-Depth approach aligned with NIST SP 800-53 and HIPAA guidance, this project evaluates existing vulnerabilities, assesses organizational risk, and recommends layered administrative, technical, and physical security controls to strengthen the organization's overall cybersecurity posture and protect consumer trust.

- Examines cybersecurity risks affecting the Nestlé Gerber Parent Resource Center
 - Focuses on protection of sensitive parent and child PII and health-related data
 - Identifies physical and logical access control weaknesses
 - Applies a Defense-in-Depth strategy aligned with NIST and HIPAA guidance
 - Recommends layered administrative, technical, and physical security controls
 - Aims to reduce risk, ensure compliance, and preserve consumer trust
- 

EXECUTIVE SUMMARY

The Nestlé Gerber Parent Resource Center (PRC) operates in a shared, high-traffic environment that exposes sensitive parent and child information to elevated cybersecurity risks due to inadequate physical and logical access controls. These conditions increase the likelihood of unauthorized access, data exposure, and regulatory non-compliance, potentially undermining consumer trust and organizational integrity. This project addresses the need to strengthen the PRC's security posture by enhancing access control processes and implementing a layered protection strategy. The proposed solution applies a Defense-in-Depth approach that integrates administrative, technical, and physical safeguards to reduce risk, improve data protection, and support compliance with established cybersecurity standards and privacy requirements.

- *PRC operates in a high-traffic environment with elevated access risks*
- *Sensitive parent and child data vulnerable to unauthorized exposure*
- *Inconsistent access controls increase likelihood of breaches and compliance issues*
- *Need to strengthen protection of critical information assets*
- *Defense-in-Depth strategy proposed as the overall solution*
- *Combines administrative, technical, and physical safeguards*
- *Aims to reduce risk, improve security posture, and preserve consumer trust*

ORGANIZATION PROFILE AND PROBLEM STATEMENT



THE ORGANIZATION

Organization: Nestlé Gerber (Parent Resource Center focus)

Nestlé Gerber is a division of Nestlé focused on the development, manufacturing, and distribution of nutrition products for infants, children, and adults with specialized dietary needs. The organization operates within a healthcare-adjacent environment, supporting products intended for ingestion, including infant formula, medical nutrition, and hypoallergenic food products.

Mission Statement (Adapted):

Nestlé Gerber's mission is to provide safe, high-quality, and nutritionally appropriate products that support healthy growth and development while maintaining consumer trust, regulatory compliance, and product safety across its global operations.

The Parent Resource Center (PRC) serves as a critical consumer-facing operation, acting as an intake and documentation hub for product concerns, nutritional guidance, and escalation to qualified specialists when necessary.

SERVICES

Nestlé Gerber provides the following key services supported by its computing environment:

- I. Consumer and caregiver support for Gerber nutrition products
- II. Nutritional education and product guidance for infants and adults
- III. Documentation and escalation of product concerns to dietitians and specialists
- IV. Management of product quality data, including batch codes and UPC tracking
- V. Distribution of educational materials, coupons, and infant milestone information
- VI. Limited support for non-ingestion products such as baby clothing returns

These services rely on centralized knowledge bases, internal communication platforms, and data collection systems that handle sensitive consumer and health-related information.

SECURITY VULNERABILITIES AND THREATS

Nestlé Gerber's computing environment faces several security vulnerabilities and threats that can be mitigated through a **Defense-in-Depth (DiD)** and **Zero Trust** approach.

Identified Vulnerabilities and Threats

➤ **Web and Application Risks (OWASP Top 10)**

Broken access control, Insecure authentication mechanisms, Insufficient input validation for consumer-submitted data

➤ **Identity and Access Management Weaknesses**

Over-privileged user accounts, Inconsistent enforcement of multi-factor authentication, High user turnover increasing credential misuse risk

➤ **Data Exposure Risks**

Storage and processing of PII and health-related data involving minors, AI-assisted call documentation without clear governance controls

➤ **Insider Threat and Operational Risk**

High reliance on temporary workers, Limited security training, High employee turnover rates

➤ **Physical and Infrastructure Weaknesses**

Partial badge access enforcement, Inadequate segmentation between sensitive and non-sensitive work areas, Poorly maintained workstations and cabling

These weaknesses increase the likelihood of data breaches, regulatory violations, and disruption to consumer trust if not addressed.

Purpose Statement

The purpose of this technical report is to assess cybersecurity risks within Nestlé Gerber's Parent Resource Center and present defense-in-depth security control recommendations to improve the organization's overall cybersecurity posture and protect sensitive consumer and healthcare-adjacent data.

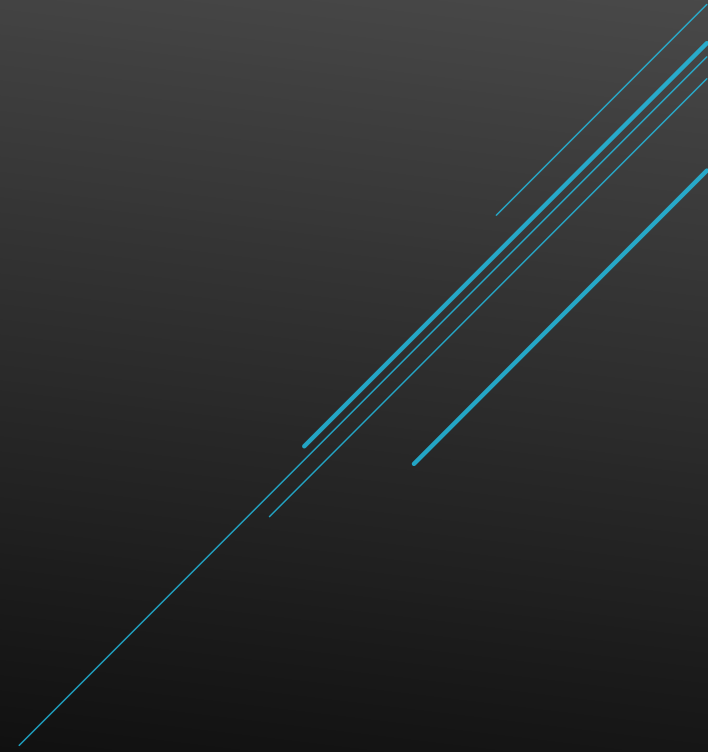
Problem Statement

Nestlé Gerber's Parent Resource Center is exposed to elevated cybersecurity risk due to inconsistent implementation of administrative, technical, and physical security controls across systems that process sensitive consumer and health-related data. These weaknesses conflict with the organization's mission to provide safe, trustworthy nutrition products. If these risks are not addressed, Nestlé Gerber may face increased likelihood of data breaches, regulatory non-compliance, operational disruptions, and loss of consumer trust.



PROBLEM STATEMENT

SECURITY CONTROL SELECTION



REVISED PROBLEM STATEMENT

The Nestlé Gerber Parent Resource Center (PRC) currently operates within a shared, high-traffic office environment that lacks sufficient physical and logical access controls. This design creates a **broken access control condition**, exposing sensitive parent and child information to unauthorized observation, access, and misuse.

Physical Access Vulnerability

The PRC cubicles are located adjacent to common hallways, meeting rooms, training areas, and other departmental workspaces. Multiple entry points into the PRC area are not protected by access-controlled doors, allowing unrestricted foot traffic. This exposes sensitive in-person conversations and on-screen data to unauthorized personnel.

Logical Access Vulnerability

PRC systems operate on the same internal network as other departments without sufficient segmentation or enforced role-based access controls. Users with excessive or inherited privileges may access systems or data beyond their job function, increasing the risk of unauthorized data disclosure or modification.

This vulnerability directly impacts Nestle Gerber's organization's security posture by undermining fundamental principles:

Confidentiality: Sensitive Personally Identifiable Information (PII) and health-related data concerning minors can potentially be viewed by unauthorized personnel through physical access or intercepted via logical connections.

Integrity: Unrestricted or poorly enforced system access could allow malicious actors or even well-meaning but overly privileged users to alter critical records related to PRC operations, consumer interactions, or sensitive data handling processes without proper authorization checks (as mandated by frameworks like NIST SP 800-53 and regulations such as GDPR/HIPAA).

Availability: Increased likelihood of accidental or malicious disruption to PRC systems due to lack of network isolation and privilege control.

Therefore, this project aims to analyze the specific broken/inadequate access control issues in the Nestlé Gerber PRC environment and recommend appropriate administrative, technical, and physical controls to mitigate these risks and strengthen our overall security posture. (Reference: NIST SP 800-53 AC Series; GDPR/HIPAA Articles related to data protection and access).



ALTERNATIVE SECURITY CONTROLS

Potential Control Solutions

Administrative Alternatives

- Implement stricter user authorization review processes.
- Enforce a clear "least privilege" policy document with specific definitions for PRC staff roles.
- Define acceptable use policies (AUP) specifically for data access and system usage in the PRC.

Technical Alternatives

- Network Segmentation/Isolation to create a dedicated, hardened network segment strictly for PRC systems, preventing unauthorized lateral movement or connection from other departments/training areas.
- Implement strict Access Control Lists (ACLs) on all network devices and servers housing PRC data/systems.

Physical Alternatives

- Install dedicated door locks requiring access badges/pins specifically for the PRC room(s).
- Increase physical cubicle depth significantly to obscure adjacent workstations.
- Create a private, secured alcove or separate small office space exclusively for certain PRC functions (e.g., handling sensitive data) within the current location.



QUALITATIVE ANALYSIS OF SECURITY CONTROLS TECHNICAL

Analysis of Alternative Control Measures

The selection of security controls must address both physical and logical access vulnerabilities effectively, balancing cost, feasibility, implementation effort, user experience, and alignment with organizational policies.

Network Segmentation (Technical)

- *Effectiveness*: High. Isolating PRC assets removes direct connectivity risks from other less secure networks.
- *Cost/Feasibility*: Moderate to High (network hardware, potential reconfiguration costs).
- *Implementation Effort*: Medium. Requires planning and execution by the network team; might necessitate firewall rules or VLAN setup.

Strict ACLs on Servers & Devices (Technical)

- *Effectiveness*: High for logical access control.
- *Cost/Feasibility*: Low to Medium (administrative effort, potential software licenses).
- *Implementation Effort*: Low. Configuration of existing network and server devices.



QUALITATIVE ANALYSIS OF SECURITY CONTROLS PHYSICAL

Analysis of Alternative Control Measures

Dedicated Door Locks (Physical)

- *Effectiveness*: High for preventing physical access.
- *Cost/Feasibility*: Low to Medium (cost of locks/cards, installation).
- *Implementation Effort*: Very Low. Primarily an installation task by Physical Security.

Increased Cubicle Depth (Physical)

- *Effectiveness*: High for reducing incidental exposure.
- *Cost/Feasibility*: Moderate (cost and time to acquire deeper panels, move desks).
- *Implementation Effort*: Low. Primarily an office/furniture reconfiguration task.

Alcove / Separate Office Space (Physical)

- *Effectiveness*: High for isolating sensitive functions.
- *Cost/Feasibility*: Medium to High (cost of construction/modification).
- *Implementation Effort*: Highest. Requires space planning and physical modifications.



SECURITY CONTROL SELECTION

Administrative

- Mandatory access recertification every 6–12 months
- Enforced least privilege policy tied to HR role definitions

Technical

- Dedicated PRC VLAN with firewall-enforced ACLs
- RBAC on all PRC applications and databases
- MFA for administrative and sensitive system access

Physical

- Badge-controlled doors at PRC entry points identified in the floor layout
- Enhanced cubicle barriers and privacy screens

This combination directly mitigates the identified broken access control conditions while remaining cost-effective and feasible.



RISK MATRIX CHART EXPLANATION

Risk Event: Unauthorized access to PRC parent and child PII due to inadequate physical and logical access controls.

- **Likelihood scale (Y):** 1 Rare, 2 Unlikely, 3 Possible, 4 Likely, 5 Almost Certain
- **Impact scale (X):** 1 Negligible, 2 Minor, 3 Moderate, 4 High, 5 Severe

LIKELIHOOD \ IMPACT	1	2	3	4	5
5 Almost Certain	M	H	H	C	C
4 Likely	M	M	H	H	C ●
3 Possible	L	M	M	H	H
2 Unlikely	L	L	M	M	H
1 Rare	L	L	L	M	M

Legend: L = Low, M = Moderate, H = High, C = Critical

Result: The identified PRC access control weakness results in a **Critical (C)** risk rating due to high likelihood of occurrence and severe regulatory, legal, and reputational impact.



APPENDIX A

Risk Matrix Table

Unauthorized Physical and Logical Access to Parent Resource Center (PRC) Systems and Data

CIA Attribute	Impact (1–5)	Likelihood (1–5)	Risk Score
Confidentiality	5 (Very High)	4 (Likely)	20
Integrity	4 (High)	3 (Possible)	12
Availability	3 (Moderate)	2 (Unlikely)	6

Total Aggregate Risk Score: 38 (High Risk)

Explanation The PRC operates in a shared workspace without adequate access controls. High foot traffic and shared network infrastructure increase the likelihood of unauthorized access, making confidentiality the most critical risk factor.

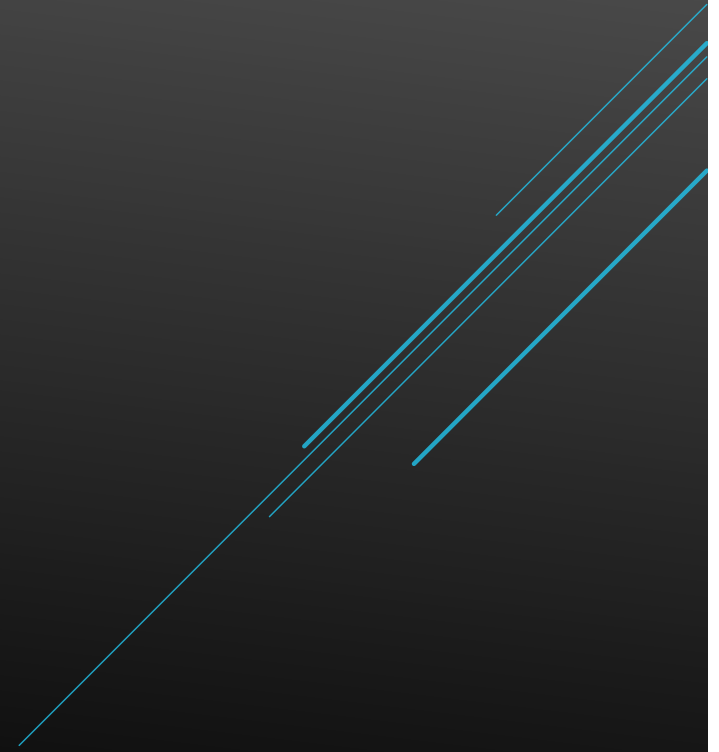


APPENDIX A CONT'D

<u>Security Control</u>	Control Upholds Confidentiality Goal	Control Upholds Integrity Goal	Control Upholds Availability Goal
Badge-Controlled Access Doors	Yes , by restricting physical access to authorized PRC personnel only.	Yes , by preventing unauthorized users from manipulating systems or records.	Yes , by reducing disruptions caused by unauthorized access.
Network Segmentation (PRC VLAN + Firewall ACLs)	Yes , by isolating sensitive PRC data from other departments.	Yes , by preventing unauthorized system modifications through lateral movement.	Yes , by limiting network congestion and attack propagation.
Role-Based Access Control (RBAC)	Yes , by limiting data access to approved job roles.	Yes, by ensuring only authorized users can modify records.	No , RBAC does not directly improve system uptime.
Multi-Factor Authentication (MFA)	Yes , by preventing unauthorized account access.	Yes , by reducing risk of compromised credentials being misused.	No , MFA does not directly improve system availability.
Access Authorization Reviews	Yes , by removing unnecessary or outdated user access.	Yes , by preventing privilege misuse and unauthorized changes.	Yes , by reducing errors caused by improper access.



IMPLEMENTATION PLAN



REVISED PROBLEM STATEMENT

The Nestlé Gerber Parent Resource Center (PRC) currently operates within a shared, high-traffic office environment that lacks sufficient physical and logical access controls. This design creates a **broken access control condition**, exposing sensitive parent and child information to unauthorized observation, access, and misuse.

Physical Access Vulnerability

The PRC cubicles are located adjacent to common hallways, meeting rooms, training areas, and other departmental workspaces. Multiple entry points into the PRC area are not protected by access-controlled doors, allowing unrestricted foot traffic. This exposes sensitive in-person conversations and on-screen data to unauthorized personnel.

Logical Access Vulnerability

PRC systems operate on the same internal network as other departments without sufficient segmentation or enforced role-based access controls. Users with excessive or inherited privileges may access systems or data beyond their job function, increasing the risk of unauthorized data disclosure or modification.

This vulnerability directly impacts Nestle Gerber's organization's security posture by undermining fundamental principles:

Confidentiality: Sensitive Personally Identifiable Information (PII) and health-related data concerning minors can potentially be viewed by unauthorized personnel through physical access or intercepted via logical connections.

Integrity: Unrestricted or poorly enforced system access could allow malicious actors or even well-meaning but overly privileged users to alter critical records related to PRC operations, consumer interactions, or sensitive data handling processes without proper authorization checks (as mandated by frameworks like NIST SP 800-53 and regulations such as GDPR/HIPAA).

Availability: Increased likelihood of accidental or malicious disruption to PRC systems due to lack of network isolation and privilege controls.

Therefore, this project aims to analyze the specific broken/inadequate access control issues in the Nestlé Gerber PRC environment and recommend appropriate administrative, technical, and physical controls to mitigate these risks and strengthen our overall security posture. (Reference: NIST SP 800-53 AC Series; GDPR/HIPAA Articles related to data protection and access).



Potential Control Solutions

Administrative Alternatives

- Implement stricter user authorization review processes.
- Enforce a clear "least privilege" policy document with specific definitions for PRC staff roles.
- Define acceptable use policies (AUP) specifically for data access and system usage in the PRC.

Technical Alternatives

- Network Segmentation/Isolation to create a dedicated, hardened network segment strictly for PRC systems, preventing unauthorized lateral movement or connection from other departments/training areas.
- Implement strict Access Control Lists (ACLs) on all network devices and servers housing PRC data/systems.

Physical Alternatives

- Install dedicated door locks requiring access badges/pins specifically for the PRC room(s).
- Increase physical cubicle depth significantly to obscure adjacent workstations.
- Create a private, secured alcove or separate small office space exclusively for certain PRC functions (e.g., handling sensitive data) within the current location.



IMPLEMENTATION FLOW DIAGRAM DEFENSE IN DEPTH

Defense in Depth/ Layered Defense Model

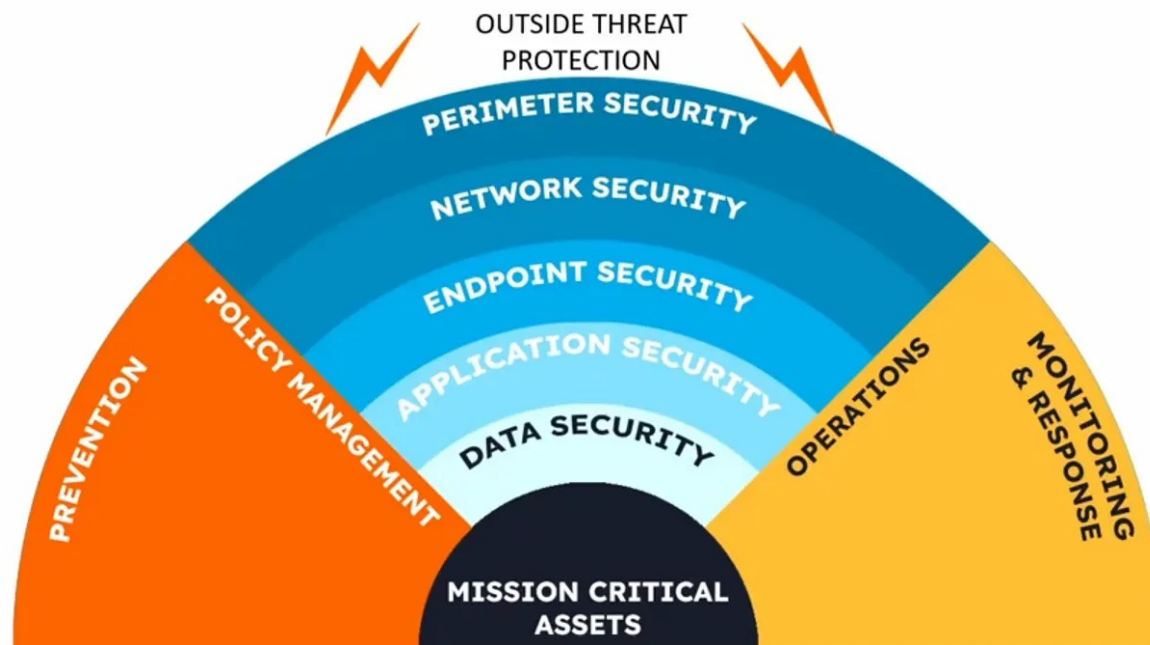
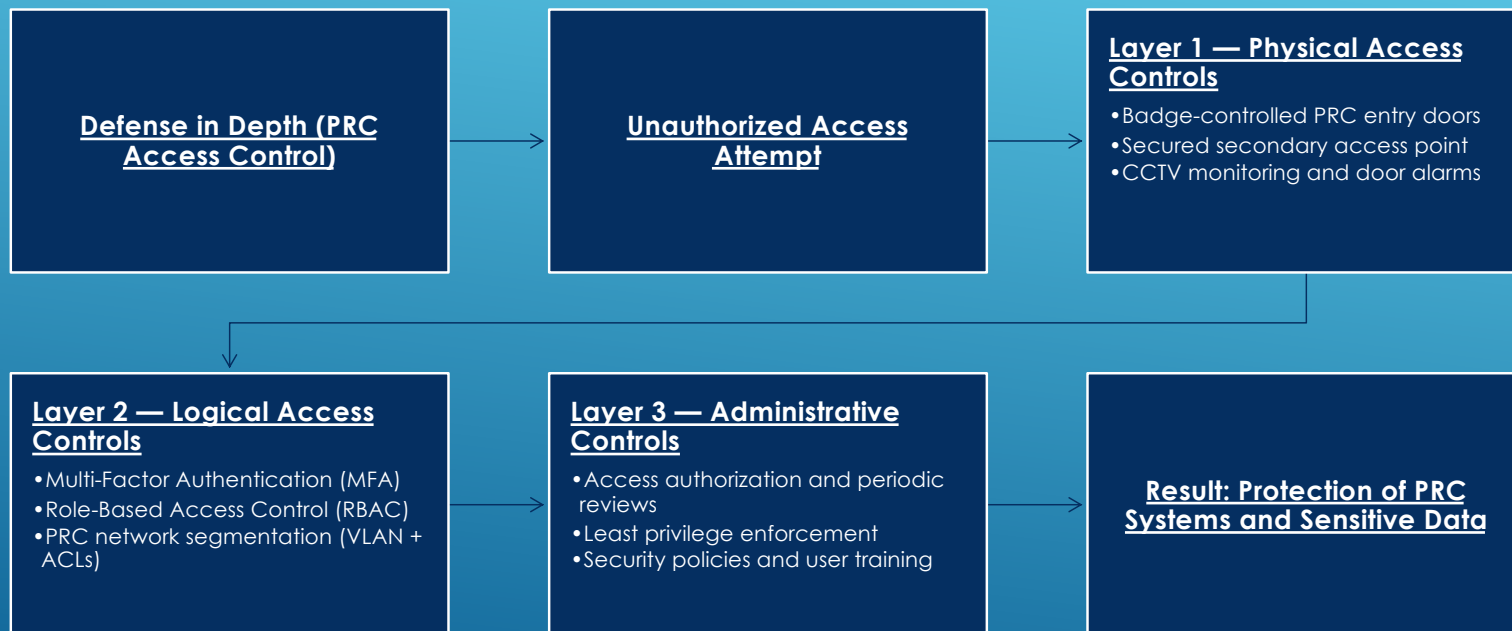


Image provided by <https://aws.plainenglish.io/the-power-of-defense-in-depth-a-layered-security-approach-22bd468e93b1>

IMPLEMENTATION FLOW DIAGRAM

DEFENSE IN DEPTH CONT'D



COST-BENEFIT ANALYSIS (CBA)

<u>Control Category</u>	<u>Implementation Costs</u>	<u>Operational Challenges</u>	<u>Expected Benefits</u>
<u>Administrative Controls</u>	Policy development, staff training, access review processes	User resistance to stricter access rules; increased administrative workload	Establishes governance, reduces insider threats, enforces least privilege
<u>Technical Controls</u>	Network segmentation, MFA licensing, RBAC configuration, monitoring tools	Integration with legacy systems; potential downtime during deployment; user friction with MFA	Prevents unauthorized logical access, reduces breach likelihood, improves monitoring
<u>Physical Controls</u>	Badge access systems, door installation, workspace modifications	Construction disruption; access delays; managing badge issuance	Prevents unauthorized physical access to sensitive conversations and data
<u>Ongoing Operations</u>	Maintenance, audits, recertification, monitoring	Continuous resource commitment; need for trained personnel	Sustained risk reduction and compliance assurance

SOLUTION VALIDATION

Testing Procedures

- Conduct pilot testing in a controlled PRC environment
- Validate administrative controls (roles, least privilege, policies)
- Test technical controls (VLAN segmentation, ACLs, RBAC, MFA)
- Verify physical access controls (badge entry, restricted workspace)
- Perform vulnerability scanning and targeted security testing

Who Will Test

- IT Network and Security Team
- Identity and Access Management / System Administrators
- Physical Security and Facilities Personnel
- PRC Supervisors and selected staff (User Acceptance Testing)

Success Criteria

- Unauthorized users cannot access PRC systems or data
- Access permissions align strictly with job roles
- Multi-Factor Authentication functions for sensitive access
- Network segmentation prevents lateral movement
- Physical access restricted to authorized personnel
- Logging and monitoring detect and record access attempts

EVALUATION AND CONTINUOUS IMPROVEMENT

Ongoing Evaluation Program

- Conduct **regular internal security assessments** simulating unauthorized access attempts across departments
- Perform controlled **red team / blue team exercises** to test administrative, technical, and physical controls
- Execute periodic phishing simulations and social engineering awareness tests
- Monitor access logs and anomaly detection systems continuously
- Perform scheduled vulnerability assessments and compliance audits

Incentive-Based Security Culture Program

- Implement a Security Engagement and Awareness Program encouraging departments to maintain strong security practices
- Establish performance metrics based on policy compliance, incident reporting, and audit outcomes
- Recognize departments demonstrating exemplary security posture
- Provide rewards or recognition for sustained compliance and proactive security behavior
- Promote a culture of trust, accountability, and responsible data handling

Markers for Success (KPIs)

- Reduction in successful unauthorized access attempts
- Increased employee reporting of suspicious activity
- Improved compliance with access control policies
- Positive audit and assessment results
- Decrease in security incidents involving sensitive PRC data

DECOMMISSION

Security controls are not retired but continuously adapted to evolving organizational needs and environments. This plan focuses on transitioning policies, procedures, and access controls to new systems, facilities, or organizational structures to ensure uninterrupted protection during acquisitions, relocations, or operational changes. While infrastructure and technologies may be updated, the underlying security principles and Defense-in-Depth strategy remain in place, preserving effective practices and maintaining protection of sensitive data across all transitions.

Lifecycle Transition Planning

- Evaluate effectiveness of existing controls prior to retirement
- Develop a transition plan to replacement security solutions
- Ensure continuity of protection during system upgrades

Technical Transition Actions

- Migrate access control configurations to new platforms
- Reconfigure network segmentation and authentication systems as needed
- Validate replacement controls before retiring legacy implementations

Data and Access Management

- Transfer access permissions and audit logs to new systems
- Revoke obsolete credentials and remove outdated privileges
- Preserve records required for compliance and auditing

Infrastructure Updates

- Remove outdated hardware and software components
- Update physical security devices as facilities evolve
- Align new controls with current organizational requirements

Post-Transition Assurance

- Verify no gaps exist in administrative, technical, or physical controls
- Conduct security assessment of the new environment
- Document transition for compliance and governance purposes

LEGAL, ETHICAL AND CULTURAL CONSIDERATIONS

Government Agencies & Regulatory Bodies

- National Institute of Standards and Technology (NIST)
- U.S. Department of Health and Human Services (HHS) — HIPAA oversight
- Federal Trade Commission (FTC) — consumer data protection and privacy enforcement
- Cybersecurity and Infrastructure Security Agency (CISA) — cybersecurity guidance and best practices

Applicable Security Standards and Frameworks

NIST Publications

- **NIST SP 800-53** — Security and Privacy Controls for Information Systems and Organizations
- **NIST SP 800-37** — Risk Management Framework (RMF)
- **NIST SP 800-53 AC Family** — Access Control requirements
- **NIST SP 800-122** — Protection of Personally Identifiable Information (PII)
- **NIST SP 800-66** — HIPAA Security Rule Implementation Guidance

Applicable Laws and Compliance Requirements

- **HIPAA** — Protection of health-related information and privacy of sensitive data
- **PCI DSS** — Protection of payment card information (if applicable)
- **State privacy laws** (e.g., consumer data protection regulations)
- **Organizational policies aligned with federal cybersecurity standards**

Privacy and Security Implementation Strategies

- Enforce strict Identity and Access Management (IAM) controls
- Apply least-privilege access to sensitive PRC data
- Encrypt sensitive information at rest and in transit
- Maintain audit trails and monitoring for compliance verification

The recommended access control solution is designed to comply with applicable federal regulations, cybersecurity standards, and privacy requirements governing sensitive parent and child information. Frameworks such as NIST SP 800-53 and related guidance provide the foundation for implementing administrative, technical, and physical safeguards, while HIPAA and PII protection standards ensure that personal and health-related data are handled securely and lawfully. Privacy strategies include strict Identity and Access Management controls, least-privilege enforcement, and encryption of sensitive data both at rest and in transit to prevent unauthorized disclosure. Security measures such as continuous monitoring, audit logging, and network segmentation further protect information throughout the implementation lifecycle. These controls support legal compliance, uphold ethical obligations to protect vulnerable populations, and promote a security-aware organizational culture that balances strong protection with responsible and transparent handling of sensitive information.

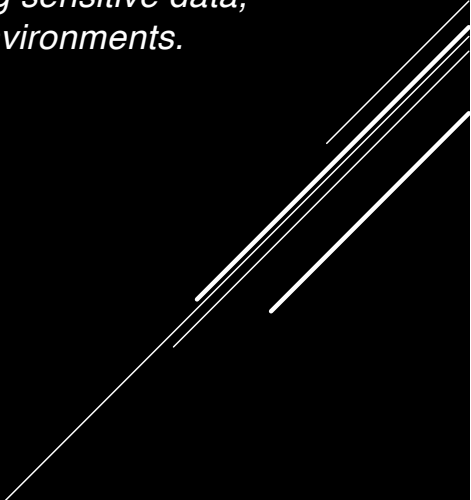
INCORPORATION OF FEEDBACK

Feedback from a technical colleague emphasized the importance of designing each slide so the audience can understand the key message at a glance. This recommendation was reinforced by my own training experience within the organization, where employees were required to quickly digest complex information related to IT systems, human resources data, and sensitive health information associated with the organization's products and services. Based on this insight, the presentation was revised to improve clarity, reduce text density, and highlight essential points on each slide to support rapid comprehension. Visual elements and concise summaries were added to ensure the material could be easily understood by audiences with diverse technical and operational backgrounds while maintaining accuracy and alignment with cybersecurity best practices.

- Feedback recommended a clear, easy “one-shot” view of each slide
- Training experience showed need to quickly process IT, HR, and health information
- Reduced text to emphasize critical takeaways
- Simplified technical language for mixed audiences
- Improved visual layout for faster comprehension
- Added visuals to reinforce key concepts
- Ensured accessibility for both technical and non-technical stakeholders

CAREER ENHANCEMENT

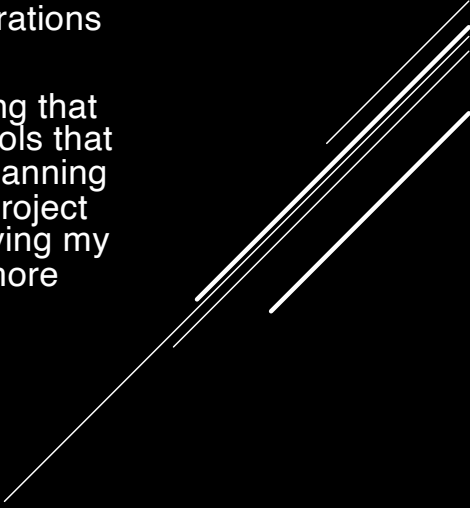
Completing this project strengthened my ability to analyze complex cybersecurity risks and design practical, layered security solutions aligned with industry frameworks such as NIST and HIPAA. The process enhanced my skills in risk assessment, access control strategy, and Defense-in-Depth implementation while reinforcing the importance of balancing security, usability, and organizational operations. Additionally, developing this presentation improved my ability to communicate technical concepts to both technical and non-technical stakeholders, a critical competency for cybersecurity professionals. These experiences directly support my career goals of advancing as an Information Security practitioner capable of protecting sensitive data, managing risk, and contributing to organizational security governance in real-world environments.

- *Strengthened cybersecurity risk assessment and analysis skills*
 - *Gained experience designing layered Defense-in-Depth solutions*
 - *Applied NIST and HIPAA guidance to a real-world scenario*
 - *Improved access control and Identity & Access Management understanding*
 - *Enhanced ability to communicate technical concepts to diverse audiences*
 - *Developed strategic thinking for organizational security planning*
 - *Advanced readiness for roles in cybersecurity and IT security management*
- 

CONCLUSION

This project provided a comprehensive evaluation of cybersecurity risks within a real-world operational environment and demonstrated how layered access control strategies can protect sensitive information while supporting organizational effectiveness. Through the analysis, design, and implementation of a Defense in Depth solution aligned with recognized frameworks, such as NIST and HIPAA guidance, I developed practical skills in risk assessment, security architecture, and strategic planning that extend beyond academic theory. The experience has significantly influenced how I approach security in my own work particularly in the development of applications and systems where security considerations must be integrated from the earliest design stages.

Completing this project also strengthened my professional perspective by reinforcing that effective cybersecurity requires anticipating failure points and building resilient controls that prevent, detect, and respond to threats. This mindset shifts planning for failure as planning for success will guide my future efforts as I pursue a career in cybersecurity. The project has equipped me with real world competencies in securing modern systems, improving my readiness to contribute to organizational security initiatives and to design safer more resilient technologies moving forward.



REFERENCES WEEK 4 & 2

- This assessment is based on the author's prior work experience and direct observation of operational workflows within the organization (*No confidential, proprietary, or restricted information was used in this analysis*).
- Whitman, M. E., & Mattord, H. J. (2022). *Principles of information security* (7th ed.). Cengage Learning.
- National Institute of Standards and Technology. *Security and Privacy Controls for Federal Information Systems and Organizations* (SP 800-53). U.S. Department of Commerce. SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations | CSRC
- National Institute of Standards and Technology. *HIPAA Security Rule Implementation Guidance* (SP 800-66). U.S. Department of Commerce. NIST SP 800-66 compliance and HIPAA compliance - SAI360
- U.S. Department of Health & Human Services. *HIPAA Security Rule*. HIPAA Security Rule | NIST
- NIST definition of PII as information that can trace or distinguish individual identity. NIST SP 800-122, Guide to Protecting the Confidentiality of Personally Identifiable Information (PII)
- Payment Card Industry Security Standards Council. *PCI DSS Overview*. How many data security standards are there? | DataGuard

REFERENCES WEEK 6

- National Institute of Standards and Technology. SP 800-53: Security and Privacy Controls. <https://csrc.nist.gov/pubs/sp/800/53/r5/final>
- National Institute of Standards and Technology. SP 800-37: Risk Management Framework. <https://csrc.nist.gov/pubs/sp/800/37/r2/final>
- National Institute of Standards and Technology. SP 800-122: Guide to Protecting PII. <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-122.pdf>
- National Institute of Standards and Technology. SP 800-66: HIPAA Security Rule Guidance. <https://csrc.nist.gov/pubs/sp/800/66/r2/final>
- U.S. Department of Health and Human Services. HIPAA Security Rule. <https://www.hhs.gov/hipaa/for-professionals/security/index.html>
- **Hanjra, A. (2025).** The Power of Defense in Depth: A Layered Security Approach. <https://aws.plainenglish.io/the-power-of-defense-in-depth-a-layered-security-approach-22bd468e93b1>
- **Whitman, M. E., & Mattord, H. J.** Principles of Information Security (7th ed.). Cengage Learning.